

Graffiticode's capability security model

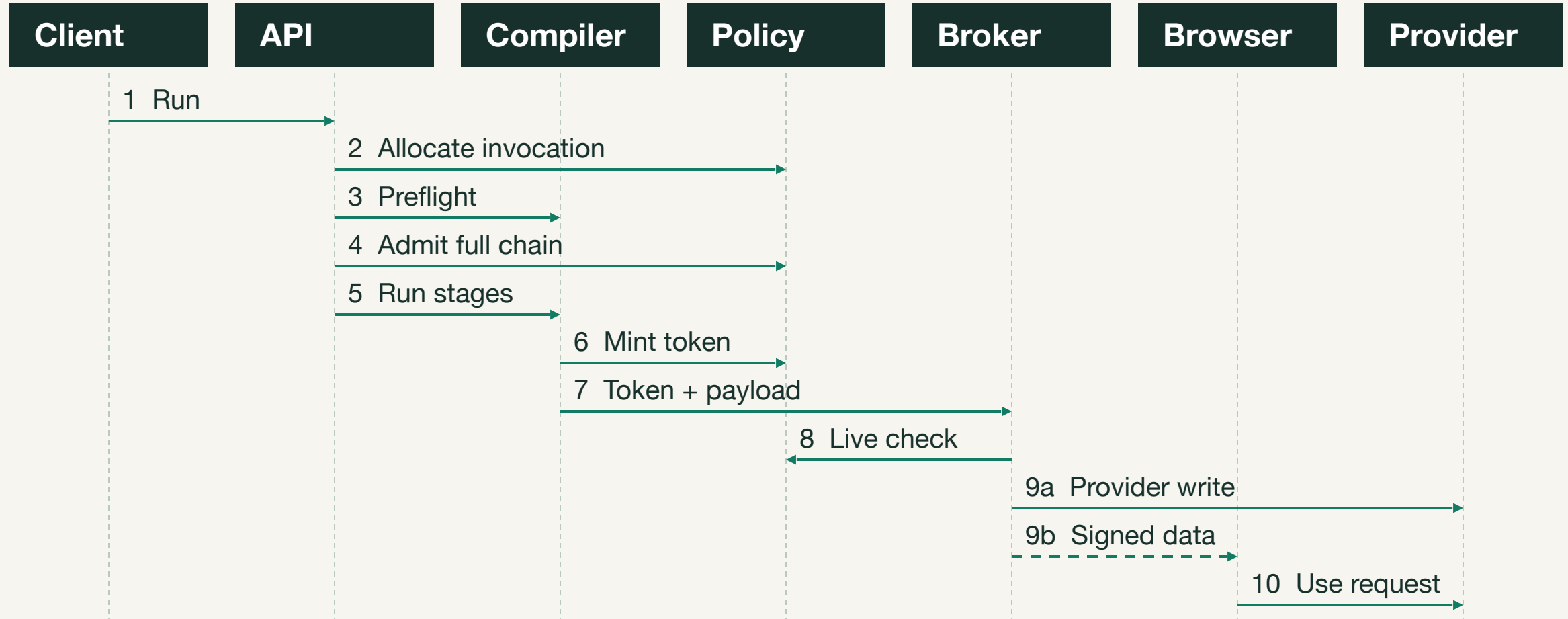
**Owner-managed grants.
Live checks for every protected call.**

A hybrid of identity-based policy and capability-style execution

Intended design, contract v2
Specification dated 2 October 2026

Services in a protected run

Auth verifies identity. API preflights every stage before Policy admits the chain.



9a: writes. 9b–10: signing, returned through the compiler and API to the browser.
Live checks repeat before every provider request or signature. Other responses are omitted.

How a protected run is authorized

- | | | |
|-----------|-----------------------------------|---|
| 01 | Bind the invocation | The gateway binds the user, connection and retry identity. |
| 02 | Admit the full chain | Compilers preflight all stages. Policy admits one pinned plan before execution. |
| 03 | Mint proof for one call | Policy rechecks access and binds a token to the operation and argument digest. |
| 04 | Recheck before each effect | Broker verifies proof and asks Policy live before each provider request or signature. |

Execution tokens expire within 60 seconds and are single-use.

Receipts prevent repeat writes on retries. Outcomes may be partial or uncertain.

Admission and live authorization

Before any stage runs

Policy admits every stage against one consistent permission snapshot.

A denied stage blocks the whole run.
External writes are not atomic.

Before each effect

Broker asks Policy again before every provider request or signature.

Revocation before the check blocks authorization. Dispatched effects may finish.

Issued browser sessions follow the provider's documented lifetime and revocation rules.

Example: share a save function

Alice shares her connection with Bob to use save-to-itembank in L0176 (Learnosity item agent).

Bob can

Run that save through Alice's connection.

Use the implicit preview signing needed to render the result.

Grants cover functions on a connection, not individual items.
Author signing stays disabled until provider validation passes, including for owners.

The grant does not include

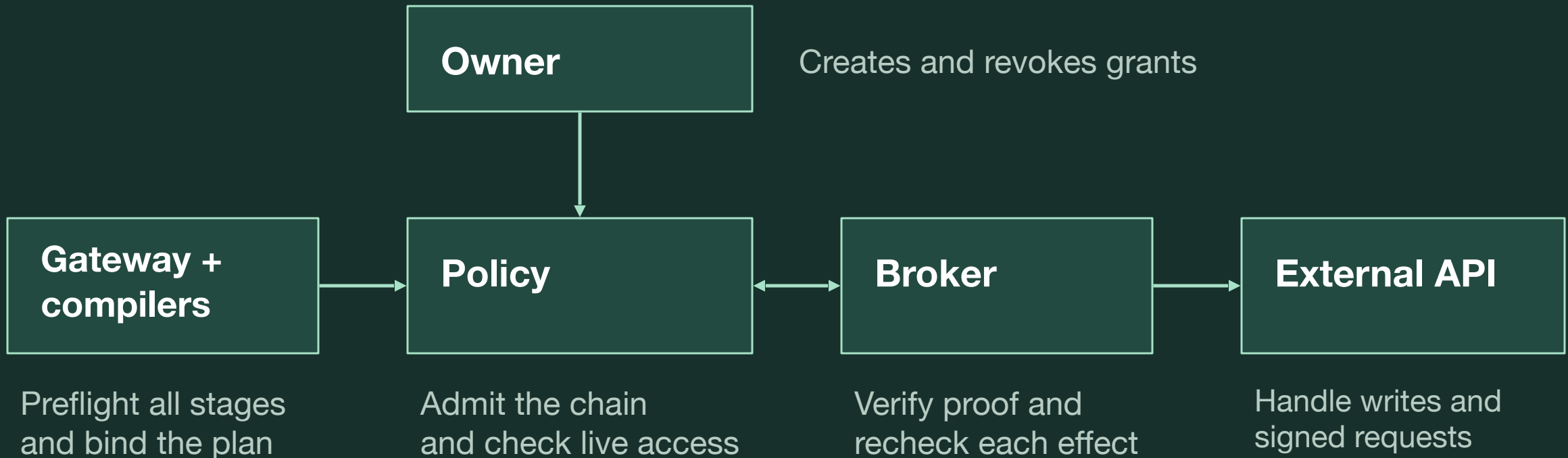
Resharing or publishing.

Author editing/deletion sessions.

A different language's save function.

Enforced security boundaries

The gateway coordinates admission. Broker enforces each operation.



Only Broker stores secrets. Enforced egress blocks compiler access to protected providers. System previews cannot write. Published views sign stored results without rerunning saves.